

Major vulnerability found in open source dev tool for Kubernetes

Apiiro's security research team disclosed recently that Argo CD, the open source developer tool for Kubernetes, has a 0-day vulnerability with 'high' severity rating.

Argo CD is a popular open source continuous delivery platform. It manages and orchestrates the execution and monitoring of application deployment post-integration.

The major software supply chain 0-day vulnerability (CVE-2022-24348) allows malicious actors to load a Kubernetes Helm Chart YAML file to the vulnerability and 'hop' from their application ecosystem to other applications' data outside of the user's scope.

The actors can read and exfiltrate secrets, tokens, and other sensitive information residing on other applications. This attack impacts privilege escalation, sensitive information disclosure, lateral movement attacks, and more.



Secondly, because application files usually contain an assortment of transitive values of secrets, tokens, and environmental sensitive settings – this can effectively be used by attackers to further expand their campaign by moving laterally through different services and escalating their privileges to gain more ground on the system and target an organisation's resources.

The advisory from GitHub urges users of Argo CD to update their installation to one of the fixed versions.

ActiveState survey reveals the current state of software supply chain security

ActiveState has announced the results of its '2021 State of Software Supply Chain Security' survey. The findings provide insights into the security challenges of the software industry's open source supply chain, which include the security



of open source components, as well as the security and integrity of key software development processes. The results point to the fact that software supply chain security is still in its infancy.

ActiveState's survey provides actionable insights for software vendors into

how they can improve the security and integrity of their software development processes. Securing the software supply chain encompasses vulnerability remediation (not covered in this survey) and the implementation of controls throughout the software development process.

The survey's results, which were garnered from the responses of more than 1,500 developers, security professionals and open source leaders at organisations of all sizes worldwide, point to the immaturity of supply chain security across the software industry. Areas of concern include the implicit trust that a worryingly high percentage of organisations (32 per cent) place in open source repositories which fail to deliver any guarantees as to the security and integrity of the software they provide, as well as the low levels of build reproducibility (only 22 per cent of organisations), making it difficult for anything built from source code to be deemed secure.

Loreli Cadapan, vice president, Product Management, ActiveState, said: "Much more work is required to address the software industry's supply chain security shortcomings. However, integrating multiple point solutions to create an end-to-end secure software supply chain is a non-trivial undertaking. To overcome this challenge, organisations should look for a turnkey, out-of-the-box solution to quickly secure their software supply chain."

Ambrosus Core launches developer funding programme

Ambrosus Core, the technical foundation of Ambrosus Ecosystem, has announced



the launch of a substantial developer funding programme — US\$ 10 million for developers deploying decentralised finance (DeFi) applications and other solutions on the Ambrosus blockchain.

Ambrosus is a fully operational Layer 1 EVM-compatible blockchain protocol providing scalability, zero-knowledge proof data security, and built-in data storage capacity.